



Q6

Compare against NIST CSF and identify control gaps

5 Marks

Objective: Assess the victim organisation against the five NIST CSF functions and list where controls were missing or weak.

Step-by-Step Algorithm

Step	Phase	Action	Command / Tool	What You Should See
1	SETUP	Write down the five NIST CSF functions as a checklist.	NIST CSF	Identify/Protect/Detect/Respond/Recover
2	ANALYSE	For each function, ask what the organisation did or failed to do.	Breach facts	Notes per function
3	TEST	Rate each function as Adequate, Partial or Missing.	Maturity scale	Rating per function
4	ANALYSE	For weak functions, state the specific control gap.	—	Gap statement
5	REPORT	Record the CSF assessment table and highlight the biggest gap.	Table template	CSF gap table

Phase key: ● SETUP · ● CONFIGURE · ● EXECUTE · ● TEST · ● ANALYSE · ● REPORT · ● FINISH

Worked Example (with sample values & output)

NIST CSF gap assessment (Acme HealthCare)

CSF function	Rating	Gap identified
Identify	Partial	No up-to-date asset / data inventory
Protect	Missing	No MFA; weak email filtering
Detect	Missing	No monitoring of large data exports
Respond	Partial	IR plan existed but response was slow
Recover	Partial	Backups existed but were not tested

Biggest gap: the Detect function. The exfiltration went unnoticed until systems were locked, showing monitoring was the weakest area.

Reusable Template

The Capital One Cloud Data Breach (July 2019):

The **2019 Capital One data breach** is a landmark cloud security incident that exposed the personal information of over **100 million individuals**. It highlighted how a single misconfiguration in cloud-native infrastructure can lead to massive data exposure.

CSF assessment template (rate each Adequate / Partial / Missing)



CSF function	Rating	Gap identified
Identify	Partial	Adequate tracking of primary servers, but failed to properly assess security risks associated with over-privileged Identity and Access Management (IAM) role assignments in cloud services.
Protect	MISSING	Severe WAF misconfiguration coupled with excessively permissive cloud permissions (Assume Role capability allowed full read access to all backup data stores).
Detect	MISSING	No active cloud-layer monitoring or anomaly alerts to flag massive, rapid data duplication and download requests from AWS S3 buckets to external IP addresses.
Respond	Partial	The Incident Response (IR) plan was properly enacted, but only <i>after</i> an external tip-off. Internal detection mechanisms completely failed to independently identify or flag the malicious operations.
Recover	Adequate	Systems did not suffer structural damage or operational encryption, allowing data containment and configuration remediation to finish quickly once the vulnerability was disclosed.

Your Output / Screenshot (paste result here):

- **Attack Date:** The data exfiltration occurred in March 2019, but the breach was not discovered until it was reported via Capital One's vulnerability disclosure program on July 17, 2019.
- **Threat Actor:** Executed by a lone hacker, Paige Thompson (a former Amazon Web Services software engineer operating under the alias "erratic").
- **Initial Access Route:** The attacker exploited a misconfigured open-source Web Application Firewall (WAF) hosted on AWS. The WAF was over-privileged, allowing the attacker to execute a Server-Side Request Forgery (SSRF) attack to query the AWS Metadata Service and obtain temporary administrative IAM role credentials.
- **Exploitation Scope:** Armed with the stolen administrative credentials, the attacker bypassed traditional boundary defenses, listed the contents of cloud storage storage units, and cloned over 700 buckets containing customer credit card applications, credit scores, and social security numbers.
- **Business & Financial Impact:** Capital One was hit with an \$80 million regulatory fine from the OCC, settled a class-action lawsuit for \$190 million, and incurred over \$150 million in direct remediation and customer notification costs.

Biggest gap: The **Detect and Protect functions** were the weakest areas. The configuration allowed a standard web application firewall role to read sensitive customer databases directly, while the lack of cloud logging alerts meant the exfiltration went completely unnoticed for nearly four months until an outside source reported it.